



Treinamento em Segurança Ofensiva 2024/2025

Relatório de Atividades	
Módulo 4:	Pentest em Aplicações Web
Atividade 3:	Vulnerabilidades no Processo de Autenticação
Nome:	Luiz Eduardo de Andrade

1. Introdução

Esta atividade faz parte do módulo *Pentest em Aplicações Web*, para a qual utilizamos a sala Enumeration & Brute Force, do TryHackMe: <https://tryhackme.com/room/enumerationbruteforce>. Esta sala é uma das salas dedicadas ao módulo de Pentest em Aplicações Web.

No contexto desta sala, nosso foco é:

- 1) Forçar a aplicação ao maior número de erros possíveis para descobrir caminhos internos, detalhes de banco de dados, informações de usuários, através das mensagens de erro, quanto mais detalhadas melhor para descobrir maiores informações, importante também para fazer enumeração de usuários válidos e reduzir o escopo da força bruta;
- 2) Explorar o campo de redefinição de senha tanto através de e-mail, perguntas de segurança, redefinição por SMS, tokens previsíveis, expiração de tokens, divulgação de informações e transporte inseguro para termos acesso a uma conta sem ter as credenciais de login e senha.
- 3) Utilizar as falhas de segurança da autenticação básica que requer apenas usuário e senha, através de força bruta interceptação de protocolos que não utilizem HTTPS.

A sala do Try Hack Me é composta por três tarefas:

- 1) Task 3: Enumerando usuários por meio de erros detalhados.
- 2) Task 4: Explorando lógica de redefinição de senha vulnerável.
- 3) Task 5: Explorando a autenticação básica HTTP.

2.1. Configuração do ambiente

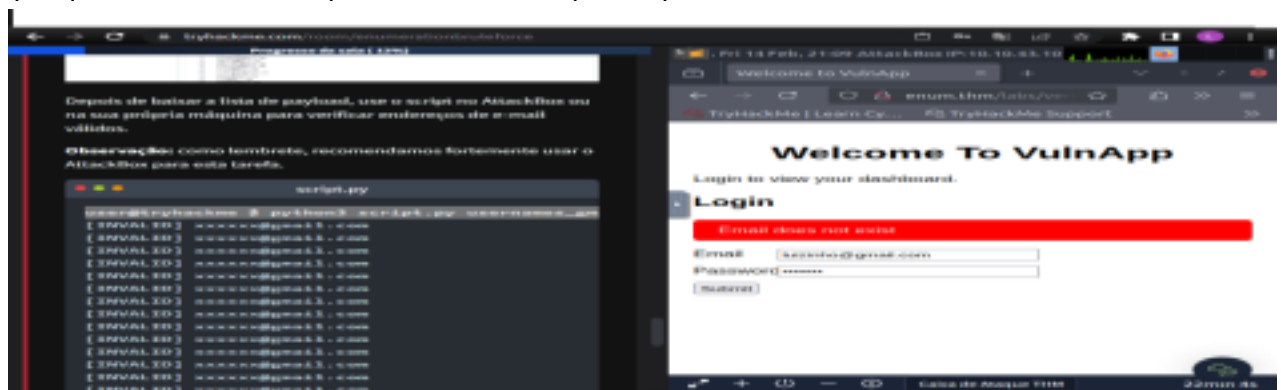
Os seguintes passos foram necessários para configurar o ambiente necessário para o desenvolvimento das atividades:

1) Início da máquina-alvo: iniciei a máquina disponibilizada pela sala do TryHackMe. 2) Configuração da AttackBox: Utilizei a AttackBox para executar os comandos Nmap necessários durante as tarefas.

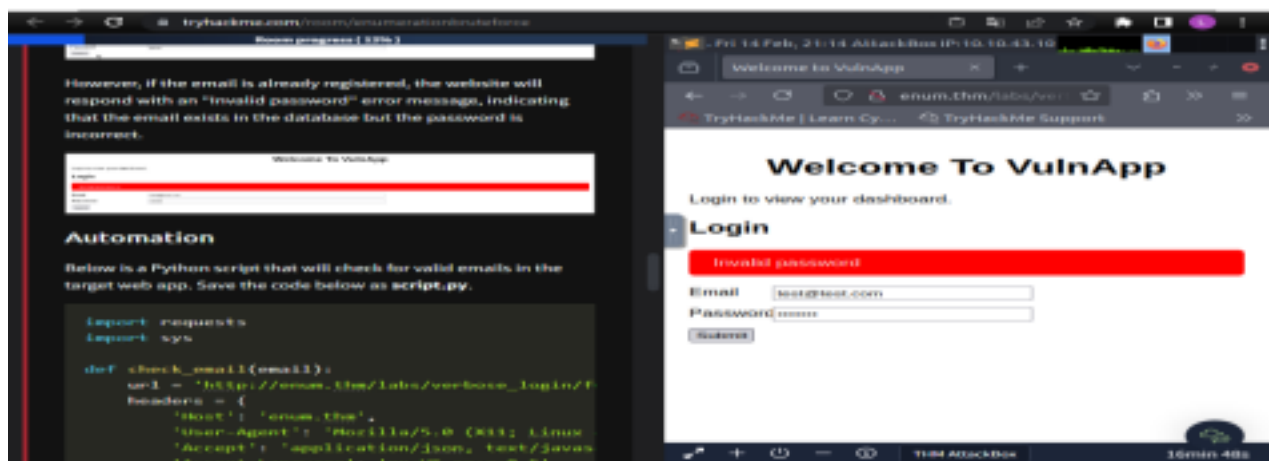
2.2. Atividade prática:

O objetivo desta atividade prática é realizar as 3 tarefas do Try Hack Me.

2.3. Task 3 - Enumerando usuários por meio de erros detalhados. Passo 1 – Tentar qualquer e-mail e senha para verificar a resposta que será dada

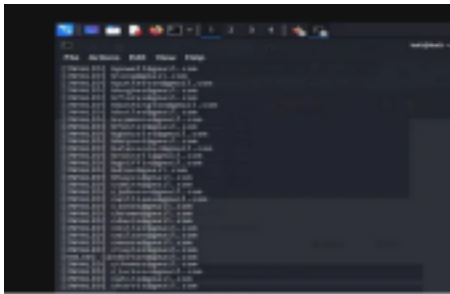


Passo 2 – Utilizar um e-mail válido mas com uma senha que não está correta

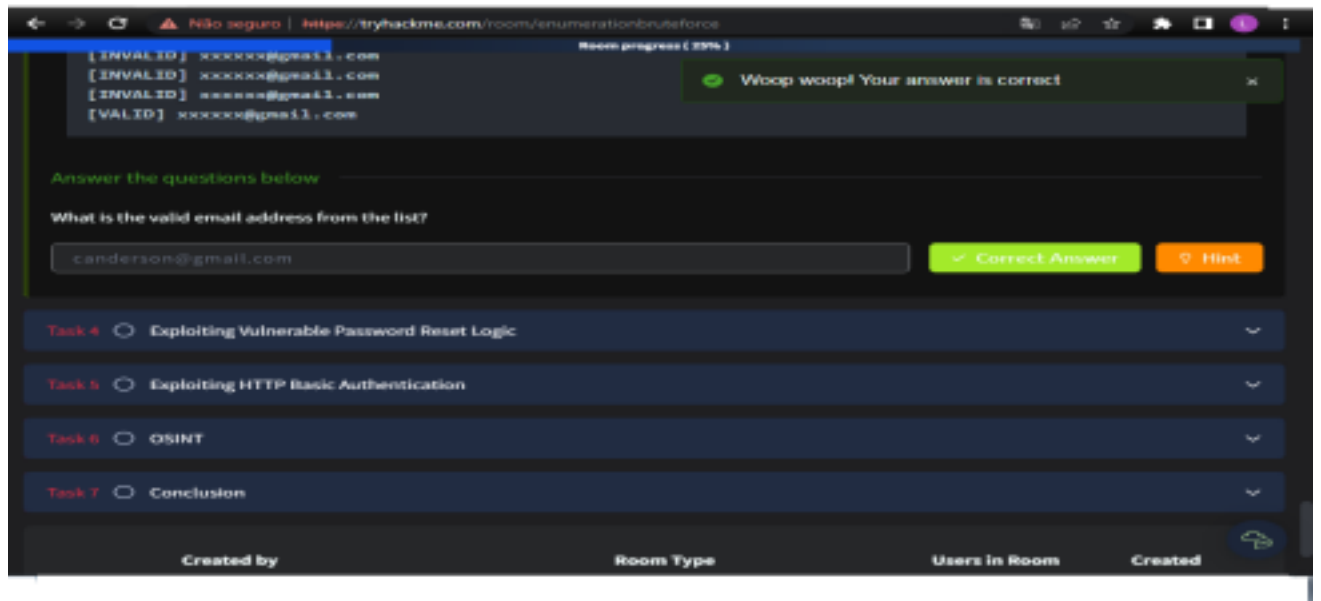


2

Passo 3 – Executar o script. py junto com a lista de nome baixadas no git hub.



Passo 4 – Concluiu o laboratório



2.4. Task 4 - Explorando lógica de redefinição de senha vulnerável. Passo 1 – Acessar o site http://enum.thm/labs/predictable_tokens/



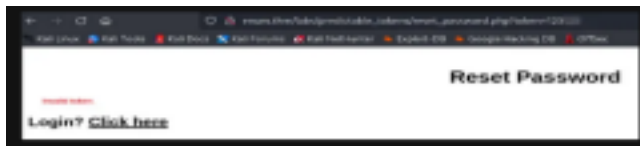
3

Passo 2 – Clique em esqueci minha senha e coloque o e-mail admin@admin

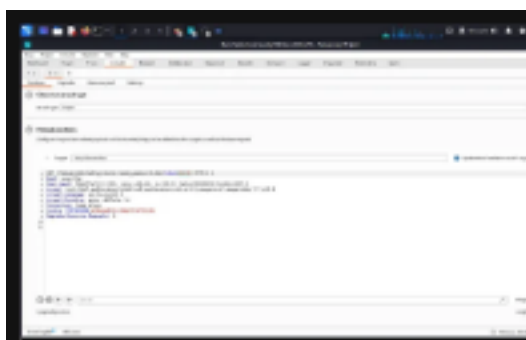


Passo 3 – O link foi enviado para o e-mail cadastrado

Passo 4 – O token informa que é inválido

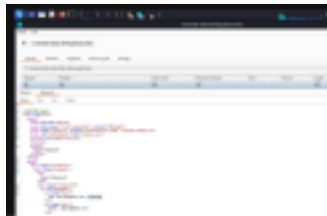


Passo 5 – Utilizando o Burp Suite e capture a url e depois envie para o Intruder



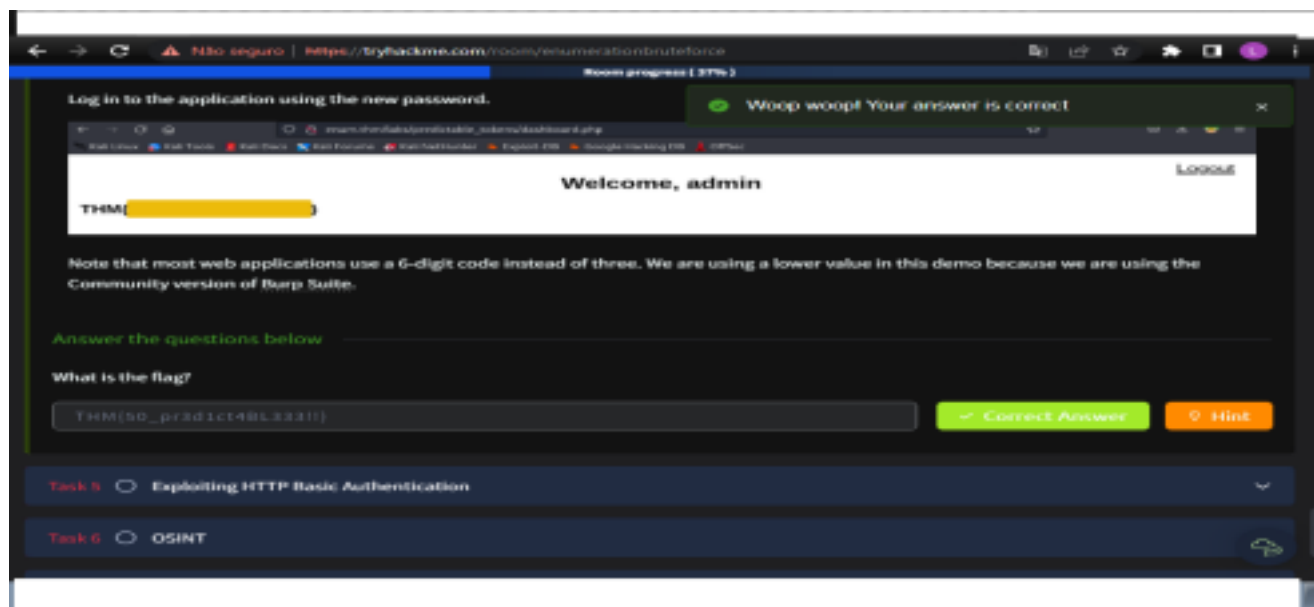
4

Passo 6 – Colocar o payloads de 100 a 200 e start attack até achar a senha do adm



Passo 7 – Logue-se como administrador e terá a chave THM{50_pr3d1ct4BL333!!} e concluirá o laboratório

5



2.5. Task 5 - Explorando a autenticação básica HTTP.

Passo 1 –

2.6. Análise dos Resultados.

Foi utilizada a máquina Kali Linux para alguns comandos

Interpretação dos resultados:

- 1) Na Task 3 Enumerando usuários por meio de erros detalhados – Quando entramos na aplicação e o e-mail não existe ele informa que o e-mail ainda não foi registrado, se aparecer a senha está incorreta quer dizer que o e-mail já foi cadastrado apenas a senha está incorreta com isso conseguimos fazer a enumeração de usuários válidos, podemos automatizar o processo com um script python.
- 2) Na Task 4 Explorando lógica de redefinição de senha vulnerável – Vamos utilizar a redefinição de senha para explorar tokens previsíveis e conseguir acesso ao usuário administrador fazendo o reset de senha e utilizando este token, conseguindo um acesso que não seria permitido.
- 3) Na Task 5 Explorando a autenticação básica HTTP - A autenticação básica HTTP é composta apenas por usuário e senha por ser simples está sujeita a ataques a RFC 7617 recomenda que o usuário e senha devem ser transportados em base 64, mas

6

base 64 não é um método de criptografia e pode ser facilmente encontrado e descoberto através de força bruta.

2.7. Mitigação.

- 1) Deixar erros genéricos que não mostrem caminhos internos, detalhes do banco de dados, informações do usuário, sempre fazer a verificação de entradas para que não informem dados confidenciais, isso pode ser usado para fazer enumeração para saber quais usuários são aceitos.
- 2) O campo esqueci minha senha é muito útil caso o usuário esqueça sua senha ou erre muitas vezes onde será necessário a redefinição, mas este campo tem que ser muito bem definido e implementado, por exemplo pode ser enviado um e-mail para o usuário supondo que apenas ele tem acesso a este e-mail, SMS segue o mesmo princípio sugere que apenas o usuário tem acesso mas o dispositivo pode ter sido comprometido não utilizar perguntas de segurança onde o atacante pode adivinhar ou conseguir estas informações em redes sociais por exemplo, transporte de links ou tokens apenas por meios seguros, os tokens tem que ter um tempo de expiração adequado, utilizar tokens que não podem ser adivinhados facilmente, mensagens de erro mais genéricas para não dar pistas para o atacante fazer enumeração;
- 3) Sempre utilizar métodos com criptografia como o HTTPS para que as informações não fiquem expostas, pode também utilizar tokens ou outra forma de autenticação para melhor proteger os dados

3. Considerações finais

Nesta sala, exploramos técnicas de vulnerabilidades no processo de autenticação,

utilizando o Burp para causar erros que especifiquem caminhos internos, banco de dados e informações do usuário, tokens previsíveis ou que não expiram, validação de entrada, divulgação de informações, transporte inseguro de dados, exploração de autenticação básica utilizando o Intruder e a conversão para base64, utilizando alguns scripts Python para agilizar o processo.

As principais lições aprendidas incluem:

- 1) Deixar os erros de forma não verbosa ou seja sem dar muitas dicas do seu sistema web, sempre deixar erros genéricos.
- 2) Implantar muito bem a função esqueci a minha senha para que ela não seja usada para conseguir acesso administrativo.
- 3) Utilizar ao menos mais uma verificação para as autenticações básica de HTTP.

7

Além do uso técnico das opções do Nmap, esta atividade reforçou a importância de documentar cada etapa do processo, incluindo os comandos utilizados, os resultados obtidos e as interpretações desses resultados. Esta prática não apenas organiza o trabalho, como garante a reprodutibilidade e facilita a comunicação técnica com outros profissionais.

Dominar essas técnicas torna o profissional mais eficiente, permitindo que ele identifique rapidamente pontos de entrada, serviços vulneráveis e possíveis caminhos para exploração dentro de um ambiente-alvo. Como mostrado nesta atividade, a coleta de informações bem executada é a base para o sucesso das próximas etapas de um teste de invasão.

4. Referências

Site: <https://tryhackme.com/room/enumerationbruteforce>

